Draft Report

On

Vulnerability Assessment and Penetration Testing



Submitted by

Shardul Sapkota

Date: 25 June 2026

To,
Broadway Infosys Nepal.

We are pleased to submit the Vulnerability Assessment and Penetration Testing (VAPT) Report prepared as part of the cybersecurity assessment assignment.

The assessment was conducted on the OWASP Broken Web Applications (OWASP BWA) laboratory environment, DVWA, and the TryHackMe VulnNet Active Active Directory environment in accordance with the assignment requirements.

The assessment included:

- Web Application Security Assessment
- Network Security Assessment
- Active Directory Security Assessment
- Security Audit Findings aligned with ISO/IEC 27001:2022

The objective of this assessment was to identify security vulnerabilities, assess the overall security posture of the laboratory environment, and provide appropriate remediation recommendations based on industry best practices.

We appreciate the opportunity provided by Broadway Infosys to perform this assessment and hope this report demonstrates the practical skills and knowledge acquired throughout the training.

……
Chief Executive Officer (CEO)

TABLE OF CONTENTS

S.NO	CONTENT	PAGE NO

1. Introduction, Objective, Scope, Methodology and Criteria 4
1.1 Introduction 4
1.2 Assessment Objective 4
1.3 Assessment Scope 4
1.4 VAPT Approach and Methodology 4
1.5 Criteria or Evaluation of Controls (Severity Level of Risk) 5
2. Executive Summary 6
3. Detailed Findings and Recommendations 7
3.1. Network VAPT 7
3.1.1 SMBv1 Enabled 7
3.1.2 Apache Tomcat Manager Interface Exposed 9
3.1.3 Exposed .bash_history File 10
3.2. Web Application VAPT 12
3.2.1 SQL Injection Vulnerability in DVWA Web Application 13
3.2.2 XPath Injection Vulnerability 14
3.2.3 Broken WordPress 15
3.2.4 Outdated Joomla Installation 17
3.2.5 Exposed phpMyAdmin Interface 18
3.2.6 Command Injection Vulnerability 19
3.2.7 Directory Listing Vulnerability 20
3.3 Active Directory Security Assessment 22
3.3.1 SMB Enumeration 22
3.3.2 Active Directory Enumeration using BloodHound 23
3.3.3 Active Directory Attack Path Analysis 25
4. Audit Findings 26
4.1 Lack of Network Segmentation 26
4.2 No Regular Backups of Critical Systems 26
4.3 Absence of IDS/IPS 27
4.4 Lack of Logging and Monitoring 27
5 Conclusion 28
6 Disclaimers & Restrictions ..... **Error! Bookmark not defined.**

1. Introduction, Objective, Scope, Methodology and Criteria

1.1 Introduction

Broadway Infosys Nepal engaged the assessor to perform a comprehensive Vulnerability Assessment and Penetration Testing (VAPT) of its laboratory environment. The assessment was conducted using the OWASP Broken Web Applications (OWASP BWA) Version 1.2 virtual machine, which provides intentionally vulnerable web applications for cybersecurity training and security testing.

The assessment also included a Network Security Assessment using the Damn Vulnerable Web Application (DVWA) in a controlled laboratory environment and an Active Directory Security Assessment using the TryHackMe VulnNet Active environment.

The objective of the assessment was to identify security vulnerabilities, evaluate the security posture of the environment, and provide remediation recommendations aligned with industry best practices, including the OWASP Top 10 and ISO/IEC 27001:2022 Information Security Management System (ISMS) controls**.**

1.2 Assessment Objective

The main objective of this assessment was to identify security vulnerabilities in the assigned laboratory environments and recommend appropriate security controls and remediation measures based on the findings identified during the assessment.

1.3 Assessment Scope

A complete Vulnerability Assessment and Penetration Testing (VAPT) of Network and Application.

1.4 VAPT Approach and Methodology

1.5 Criteria or Evaluation of Controls (Severity Level of Risk)

Our significant findings are summarized in Section II (Executive Summary) while the detailed findings are set out in Section III of the report. Each issue identified in this report is assigned a risk category as "Low", "Medium", “High”, or “Critical” with following interpretation.

Risk Grade	Characteristics
Critical	Severity level is said to be “Critical” if controls are not complied with existing control objectives. Vulnerabilities that result in a compromise of the entire system if exploited. In almost all cases, successful exploitation can result in a complete loss of confidentiality, integrity, and availability of data stored on or transmitted across the system. Compensatory controls fail to reduce the risk so as to make it immaterial. Such type of observations should be patched immediately.
High	Severity level is said to be “High” if controls are not complied with existing control objectives. Vulnerabilities that result in a compromise of the system if exploited. In most cases, successful exploitation can result in a loss of confidentiality, integrity, and availability of data stored on or transmitted across the system. Compensatory controls fail to reduce the risk so as to make it immaterial. Such type of observations should be patched immediately.
Medium	Severity level is said to be “Medium” if controls are compiled partially with existing control objectives. Vulnerabilities that result in a partial compromise of the affected system. An attacker may gain elevated privileges but does not gain complete control of the targeted system. Moderately severe vulnerabilities include those for which the impact on systems is high but accessibility to attackers is limited. Compensatory controls reduce the risk to some extent but not completely. Such type of observations should be patched within a reasonable timeline.
Low	Severity level is said to be “Low” if controls are complied with leaving behind some residual risk. Vulnerabilities that constitute a minor threat. Attackers cannot exploit these vulnerabilities across a network and successful exploitation does not result in a complete compromise of the information stored on or transmitted across the system. Compensatory controls reduce most of the risk but residual risk is still significant. Such type of observations should be patched by defining a certain timeline.

Severity/Risk = Threat * Vulnerability * Impact

2. Executive Summary

(This Section will be updated after management Response)

3. Detailed Findings and Recommendations

3.1. Network VAPT

<table>
<tr><td colspan="2">3.1.1 SMBv1 Enabled</td><td>High</td></tr>
<tr><td>Identification</td><td colspan="2"><table><tr><th>Asset</th><th>IP Address</th><th>Port</th></tr><tr><td>Trust AML</td><td>172.16.33.215</td><td>9990</td></tr></table></td></tr>
<tr><td>Condition</td><td colspan="2">It was observed that the target system had Server Message Block Version 1 (SMBv1) enabled. SMBv1 is an outdated file-sharing protocol with multiple publicly known security vulnerabilities and is no longer recommended for use.

SMB is a network file-sharing protocol used to provide shared access to files and printers. Older versions such as SMBv1 contain significant security weaknesses and have been associated with several remote code execution vulnerabilities.</td></tr>
<tr><td colspan="3"><u>Proof of concept</u>
 

Figure: SMBv1 service identified as enabled during the network security assessment.</td></tr>
<tr><td>Criteria</td><td colspan="2">As per security best practices, deprecated protocols such as SMBv1 should be disabled and replaced with supported versions such as SMBv2 or SMBv3.</td></tr>
<tr><td>Impact</td><td colspan="2">An attacker can:
i. Exploit known vulnerabilities affecting SMBv1.
ii. Gain unauthorized access to shared resources.
iii. Perform lateral movement within the network.
iv. Potentially achieve remote code execution on vulnerable systems.</td></tr>
</table>

Recommendation	It is recommended to: i. Disable SMBv1 on all systems. ii. Enable SMBv2 or SMBv3. iii. Apply the latest security patches. iv. Regularly review exposed network services.
Management Response	

3.1.2 Apache Tomcat Manager Interface Exposed	Medium

Identification

Asset/Server Name	IP Address	Port
Apache Tomcat Manager	Laboratory Environment	8080

Condition

It was observed that the Apache Tomcat Manager interface was publicly accessible during the network security assessment. Administrative interfaces such as the Tomcat Manager provide functionality to deploy, manage, and monitor web applications. If left exposed or protected with weak credentials, they may be abused by attackers to gain unauthorized access or deploy malicious applications.

Apache Tomcat is an open-source Java Servlet container commonly used to host Java-based web applications. Improperly secured Tomcat Manager interfaces can significantly increase the attack surface of a system.

Proof of concept

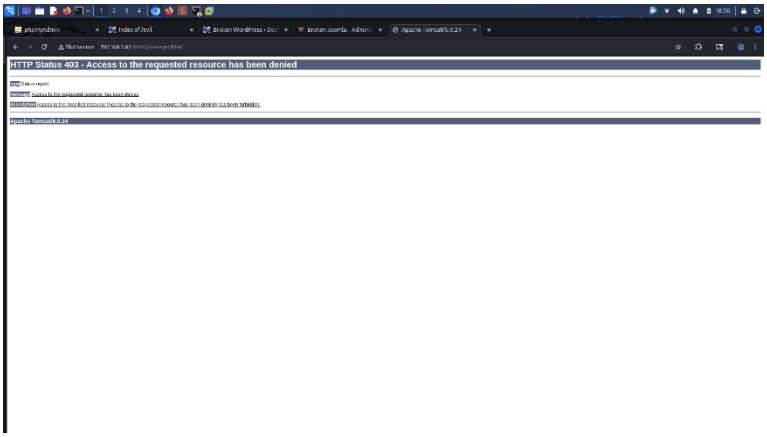


Figure: Apache Tomcat Manager interface identified during the network security assessment.

Criteria

As per security best practices, administrative interfaces should not be publicly accessible. Access should be restricted to authorized administrators through strong authentication and appropriate network access controls.

Impact

An attacker can:

i. Attempt unauthorized access to the Tomcat Manager interface.
ii.
iii. Deploy malicious web applications if valid credentials are obtained.
iv. Modify or remove deployed applications.
v. Potentially achieve remote code execution through malicious deployments.

Recommendation

It is recommended to:

i. Restrict access to the Tomcat Manager interface using firewall or IP-based access controls.
ii. Disable the management interface if it is not required.
iii. Use strong, unique administrator credentials.
iv. Regularly update Apache Tomcat to the latest supported version.

Management Response

3.1.3 Exposed .bash_history File	Medium

Identification

Asset	IP Address	Port
Linux Web Server	Laboratory Environment	N/A

Condition

It was observed that the .bash_history file was accessible during the assessment. The .bash_history file stores previously executed shell commands of Linux users. If exposed to unauthorized users, it may disclose sensitive operational information including system commands, file locations, usernames, administrative activities, and potentially credentials entered directly into the terminal.

Improper exposure of system files is considered a security misconfiguration and may provide attackers with valuable information for further exploitation.

Proof of Concept:

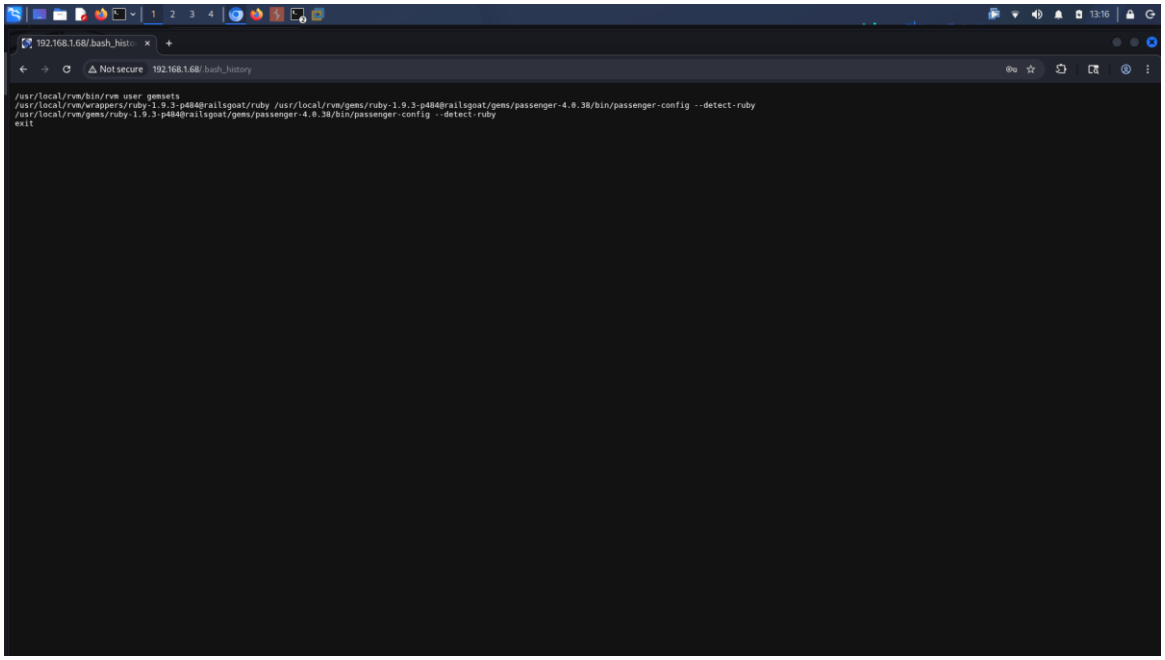


Figure: Accessible .bash_history file containing previously executed Linux commands.

Criteria

As per security best practices, sensitive system files should not be publicly accessible. Access to user home directories and shell history files should be restricted using appropriate file permissions and access controls.

Impact

An attacker can:

i. Obtain information about previously executed administrative commands. Discover usernames, file paths, and system configurations.
ii. Gather intelligence to facilitate further attacks against the target system.
iii. Potentially recover sensitive information if credentials or tokens were entered through the command line.

Recommendation

It is recommended to:

i. Restrict access permissions to the .bash_history file.
ii. Avoid entering sensitive credentials directly into the command line.

	iii. Remove sensitive information from shell history where appropriate. iv. Regularly review file permissions for sensitive system files.
Management Response	

3.2. Web Application VAPT

OWASP Top 10 Web Application Security - 2021

Reference ID	Name	Count
A01	Broken Access Control	0
A02	Cryptographic Failures	0
A03	Injection	3
A04	Insecure Design	0
A05	Security Misconfiguration	2
A06	Vulnerable and Outdated Components	2
A07	Identification and Authentication Failures	0
A08	Software and Data Integrity Failures	0
A09	Security Logging and Monitoring Failures	0
A10	Server-Side Request Forgery	0
O	Others	0
T	**Total**	**7**

3.2.1 SQL Injection Vulnerability in DVWA Web Application	Critical

Identification

Application	URL	Authenticated/ Unauthenticated	Internal/ External	Affected URL
DVWA	Laboratory Environment	Authenticated	Internal	

Condition

It was observed that the DVWA web application was vulnerable to SQL Injection due to improper validation and sanitization of user-supplied input. During testing, the id parameter accepted malicious SQL payloads, allowing SQL queries to be manipulated and executed by the backend database.

The vulnerability was verified using sqlmap, which successfully identified multiple SQL Injection techniques, including Boolean-based Blind, Error-based, Time-based Blind, and UNION Query SQL Injection. Furthermore, the tool was able to enumerate the backend MySQL database and retrieve the available database names, confirming successful exploitation.

SQL Injection is a web application vulnerability that occurs when an application incorporates untrusted user input directly into SQL queries without proper validation or parameterized statements. Successful exploitation may allow attackers to retrieve, modify, or delete sensitive information stored in the database.

Proof of Concept

```
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 5169=5169#&Submit=Submit

    Type: error-based
    Title: MySQL ⩾ 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
    Payload: id=1' AND EXTRACTVALUE(1524,CONCAT(0×5c,0×716b707071,(SELECT (ELT(1524=1524,1))),0×7178786b71))-- lOza&Submit=Submit

    Type: time-based blind
    Title: MySQL ⩾ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 1448 FROM (SELECT(SLEEP(5)))uVfT)-- vFXF&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0×716b707071,0×64626c6469504a4a4c4a787342675a676d4877556a76686a44586e716d707a4d744c4d437a504f61,0×7178786b71),NULL#&Subr
[12:37:38] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL ⩾ 5.1
[12:37:38] [INFO] fetching database names
available databases [2]:
[*] dvwa
[*] information_schema

[12:37:38] [INFO] fetched data logged to text files under '/home/shardul/.local/share/sqlmap/output/192.168.1.82'

[*] ending @ 12:37:38 /2026-06-14/
```

Figure SQLmap successfully identified SQL Injection in the id parameter and enumerated the backend MySQL databases.

Criteria

As per the OWASP Web Security Testing Guide and OWASP Top 10 (A03:2021 – Injection), all user-supplied input should be properly validated and sanitized before being processed. Applications should implement parameterized queries (prepared statements) and avoid constructing SQL statements through dynamic string concatenation.

Impact

An attacker can:

	i. Retrieve sensitive information from the backend database. ii. Enumerate database names, tables, and stored records. iii. Modify or delete database records, compromising the confidentiality, integrity, and availability (CIA) of application data.
Recommendation	**It is recommended to:** i Validate and sanitize all user-supplied input before processing. ii Implement parametrized queries.
References	**A03: Injection**
Management Response	

3.2.2 XPath Injection Vulnerability					**High**
Identification					
	Application Name	**URL**	**Authenticated/ Unauthenticated**	**Internal/ External**	**Affected URL**
	OWASP WebGoat v5.4	Laboratory Environment	Authenticated	Internal	
Condition	It was observed that the web application was vulnerable to XPath Injection due to improper validation of user-supplied input. By injecting specially crafted XPath expressions into the input field, it was possible to manipulate XPath queries executed by the application. XPath Injection is a vulnerability that occurs when user input is directly incorporated into XPath queries without proper validation, allowing attackers to bypass authentication or retrieve unauthorized information from XML data.				
Proof of Concept:					

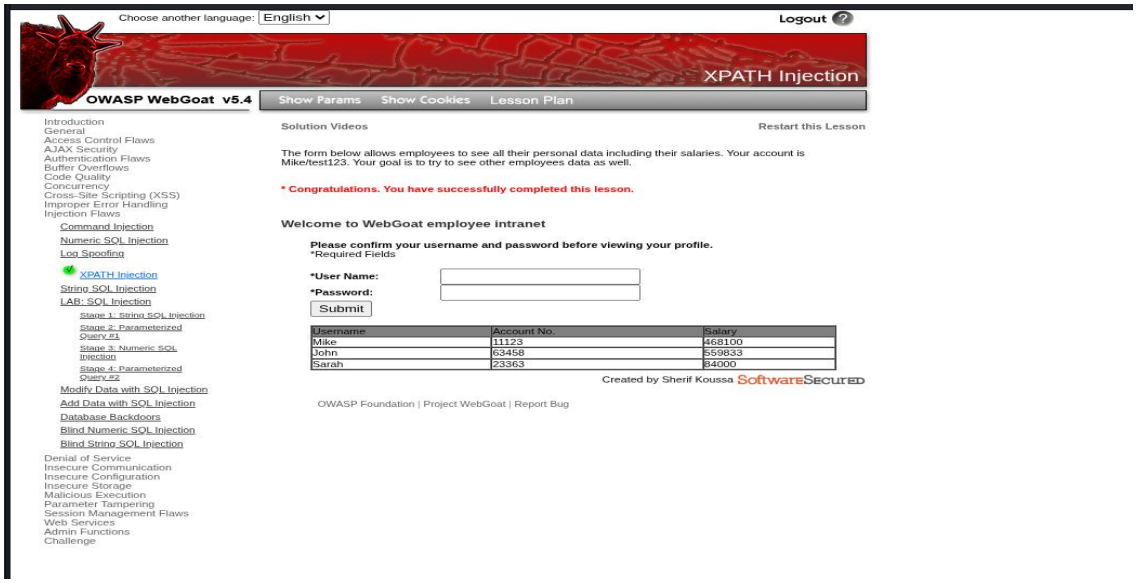


Figure: Successful exploitation of the XPath Injection vulnerability in the OWASP WebGoat application.

Criteria	As per OWASP Top 10:2021 – A03: Injection, all user input should be properly validated and parameterized before being used in XPath querie
Impact	**An attacker can:** i. Bypass authentication mechanisms. ii. Retrieve unauthorized information from XML data. iii. Manipulate application logic.
Recommendation	**It is recommended to:** i. Validate and sanitize all user input. ii. Use parameterized XPath queries where supported. iii. Restrict error messages that disclose application information.
References	**A03: Injection**
Management Response	

3.2.3 Broken WordPress	**High**

Identification

Application Name	URL	Authenticated/ Unauthenticated	Internal/ External	Affected URL
OWASP WebGoat v5.4	Laboratory Environment	Unauthenticated	Internal	

Condition	It was observed that the target system was running an outdated version of WordPress. The application was publicly accessible and could be identified through a web browser. Outdated WordPress installations are susceptible to publicly known vulnerabilities that may be exploited if security updates are not applied.

Proof of Concept:

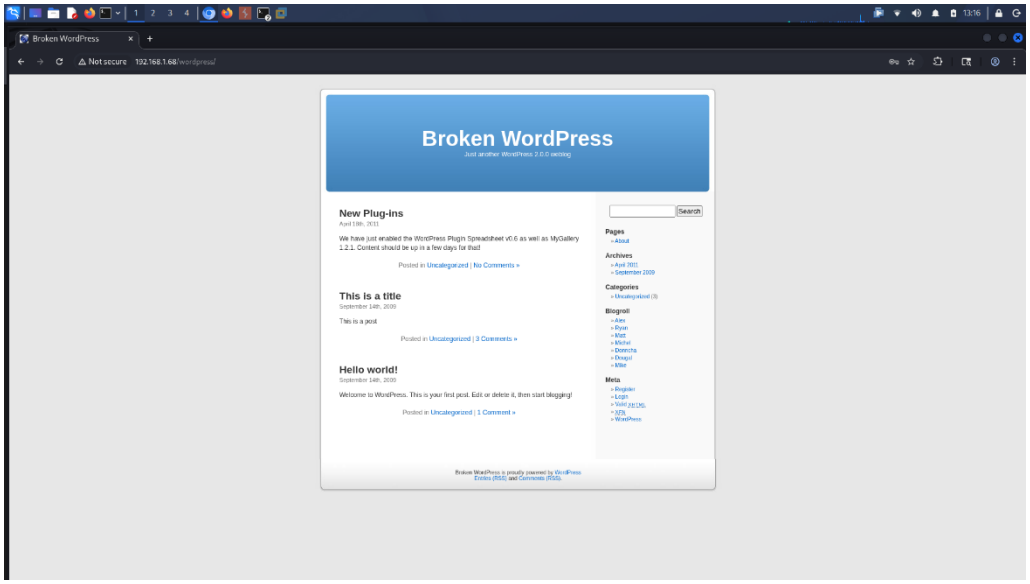


Figure: Outdated WordPress application identified on the target system.

Criteria	As per OWASP Top 10:2021 – A06: Vulnerable and Outdated Components, applications should be kept up to date and supported versions should be used to reduce exposure to known vulnerabilities.
Impact	**An attacker can:** i. Exploit publicly known vulnerabilities affecting the outdated WordPress version. ii. Gain unauthorized access or execute malicious code through vulnerable components. iii. Compromise the confidentiality, integrity, and availability of the application.
Recommendation	**It is recommended to:** i. Upgrade WordPress to the latest supported version. ii. Regularly apply security patches and updates. iii. Remove unused or vulnerable themes and plugins.
References	**A06: Vulnerable and Outdated Components**
Management Response	

3.2.4 Outdated Joomla Installation	Medium

Identification

Application Name	URL	Authenticated/ Unauthenticated	Internal/ External	Affected URL
Joomla	Laboratory Environment	Unauthenticated	Internal	

Condition

It was observed that the target system was running an outdated version of Joomla. The application was publicly accessible and identified during the assessment. Running unsupported or outdated CMS versions may expose the application to publicly disclosed vulnerabilities and security risks.

Proof of Concept:

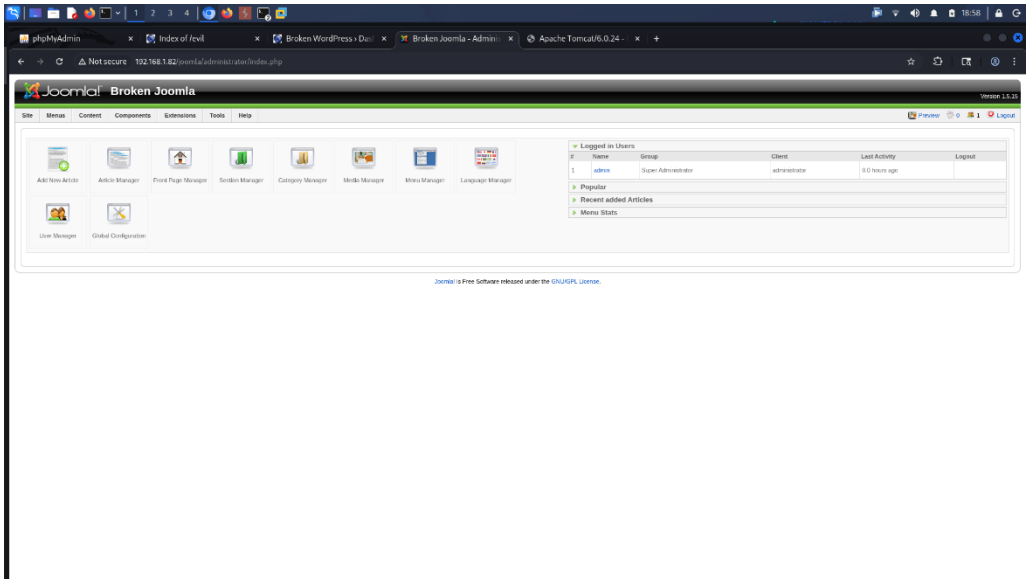


Figure: Outdated Joomla installation identified during the assessment.

Criteria

As per OWASP Top 10:2021 – A06: Vulnerable and Outdated Components, organizations should ensure software components are regularly updated and supported versions are maintained.

Impact

An attacker can:

i. Exploit known vulnerabilities in the outdated Joomla version.
ii. Apply security patches regularly.
iii. Compromise the confidentiality, integrity, and availability of application data.

Recommendation

It is recommended to:

i. Upgrade Joomla to the latest supported version.
ii. Regularly apply security patches and updates.

	iii. Remove unused extensions and components.
References	**A06: Vulnerable and Outdated Components**
Management Response	

3.2.5 Exposed phpMyAdmin Interface	**Medium**

Identification

Application Name	URL	Authenticated/ Unauthenticated	Internal/ External	Affected URL
Joomla	Laboratory Environment	Unauthenticated	Internal	

Condition

It was observed that the phpMyAdmin interface was publicly accessible during the assessment. Exposing database administration interfaces may increase the risk of unauthorized access through weak credentials, brute-force attacks, or exploitation of known vulnerabilities..

Proof of Concept:

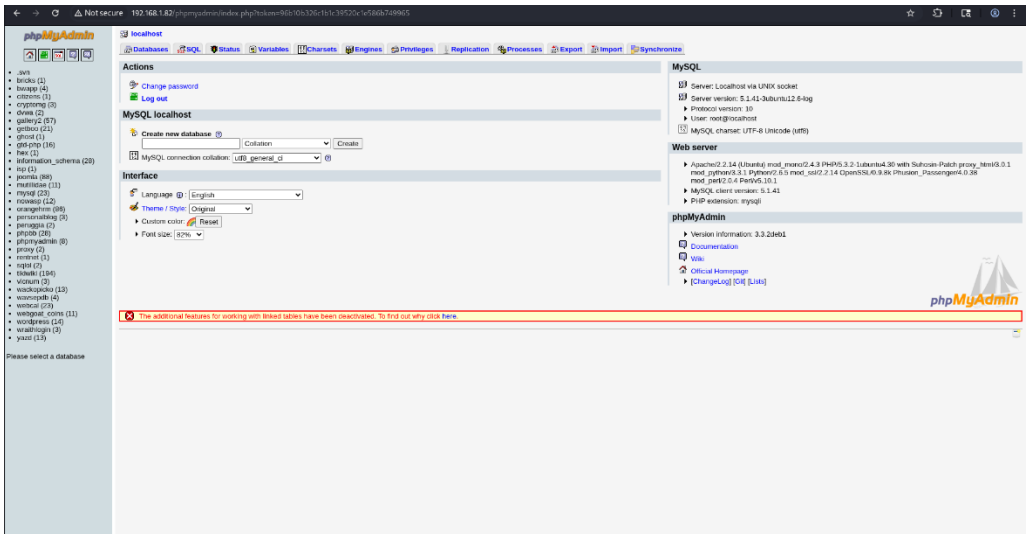


Figure: Accessible phpMyAdmin login interface identified during the assessment.

Criteria	As per OWASP Top 10:2021 – A05: Security Misconfiguration, administrative interfaces should be restricted to authorized users and should not be publicly exposed without appropriate access controls.
Impact	**An attacker can:**

	i. Attempt unauthorized access to the database administration interface. ii. Exploit known vulnerabilities in exposed phpMyAdmin installations. iii. Compromise database confidentiality, integrity, and availability if access is obtained.
Recommendation	**It is recommended to:** i. Restrict access to phpMyAdmin using network or IP-based access controls. ii. Use strong authentication and multi-factor authentication where possible. iii. Keep phpMyAdmin updated to the latest supported version. iv. Disable or remove phpMyAdmin if it is not required.
References	**A05: Security Misconfiguration**
Management Response	

3.2.6 Command Injection Vulnerability	**Critical**

Identification

Application Name	**URL**	**Authenticated/ Unauthenticated**	**Internal/ External**	**Affected URL**
DVWA	Laboratory Environment	Authenticated	Internal	

Condition

It was observed that the web application was vulnerable to Command Injection due to insufficient validation of user-supplied input. During testing, arbitrary operating system commands were executed successfully through the application's input field.

Command Injection allows attackers to execute unauthorized system commands on the underlying server, potentially leading to complete system compromise.

Proof of Concept:

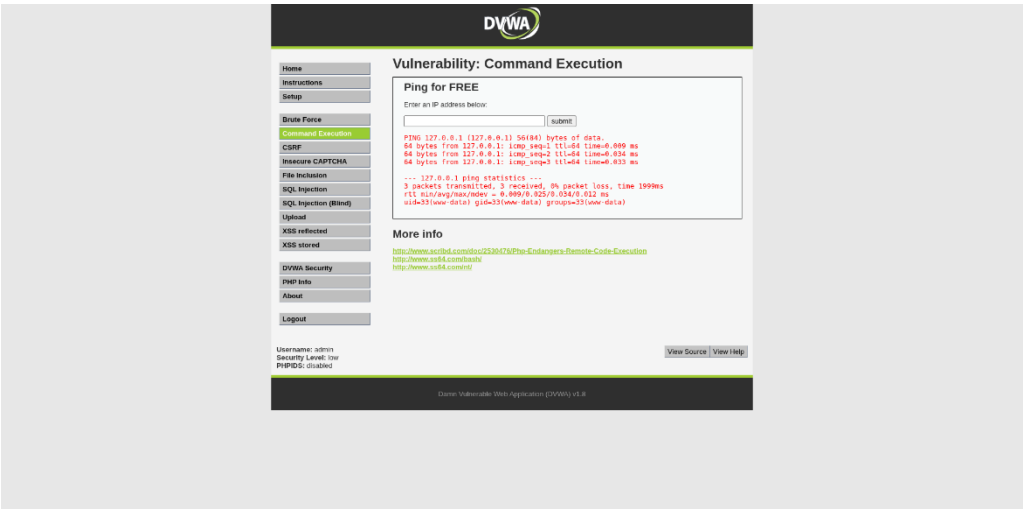


Figure: Successful exploitation of the Command Injection vulnerability through the DVWA Command Execution module.

Criteria	As per OWASP Top 10:2021 – A03: Injection, applications should validate and sanitize all user input and should never execute operating system commands using untrusted input.
Impact	**An attacker can:** i. Execute arbitrary operating system commands. ii. Access sensitive system information. iii. Compromise the underlying server. iv. Perform further post-exploitation activities.
Recommendation	**It is recommended to:** iv. Validate and sanitize all user inputs. v. Avoid passing user input directly to system commands. vi. Implement the principle of least privilege. vii. Perform regular security assessments to identify command injection vulnerabilities.
References	**A03: Injection**
Management Response	

3.2.7 Directory Listing Vulnerability					**Medium**
Identification					
Application Name	**URL**	**Authenticated/ Unauthenticated**	**Internal/ External**	**Affected URL**	

	Web Server	Laboratory Environment	Authenticated	Internal	

Condition	It was observed that directory listing was enabled on the web server, allowing users to browse the contents of the /evil/ directory. The directory contained files and subdirectories that were accessible without authentication, increasing the application's attack surface. Directory Listing is a security misconfiguration that occurs when the web server allows users to view the contents of a directory instead of restricting access or serving a default page.

Proof of Concept:

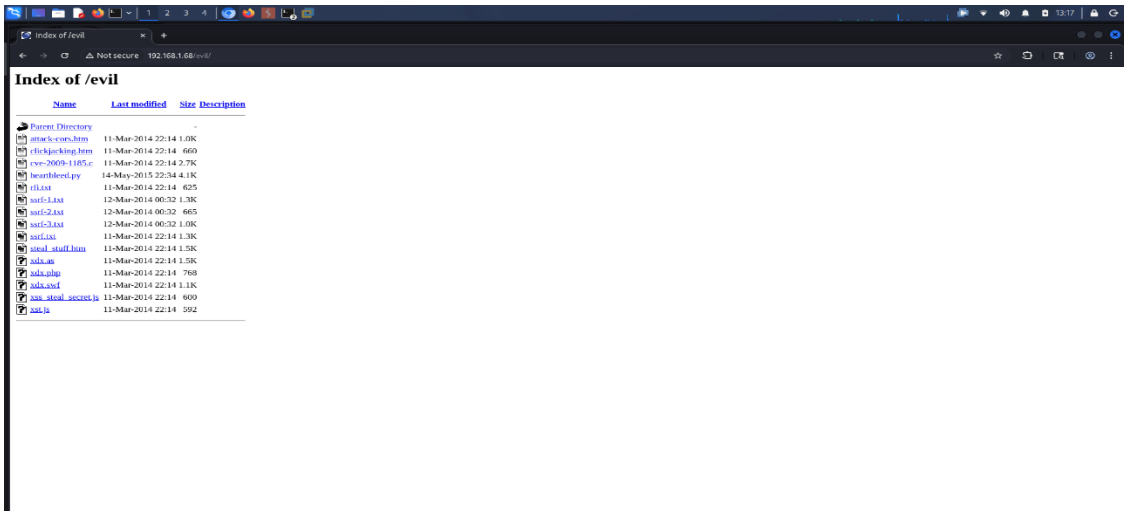


Figure: Directory listing enabled on the /evil/ directory, exposing its contents.

Criteria	As per OWASP Top 10:2021 – A05: Security Misconfiguration, directory listing should be disabled to prevent unauthorized disclosure of files and application resources.
Impact	**An attacker can:** i. Discover sensitive files and directories. ii. Gather information about the application's structure. iii. Use exposed files to facilitate further attacks.
Recommendation	**It is recommended to:** i. Disable directory listing on the web server. ii. Restrict access to sensitive directories. iii. Remove unnecessary or publicly accessible files from the web server.
References	**A05: Security Misconfiguration**

Management Response	

3.3 Active Directory Security Assessment

3.3.1 SMB Enumeration			**Medium**
Identification			
	Asset	**Environment**	**Tools Used**
	Active Directory Domain	**TryHackMe VulnNet Active**	**SMB**
Condition	It was observed that SMB enumeration provided access to information regarding shared resources, domain users, and accessible network services. SMB enumeration was performed using SMBClient and NetExec to identify available shares and gather information about the Active Directory environment. SMB (Server Message Block) is a protocol used for file and printer sharing in Windows environments. Improperly configured SMB services may disclose sensitive information that can assist attackers during reconnaissance.		
Proof of Concept: SMB enumeration was successfully performed using SMBClient and NetExec to identify accessible shares and domain information within the laboratory environment. Note: Screenshots were not preserved during the assessment			
Criteria	As per security best practices, SMB shares should be configured following the principle of least privilege, and anonymous or unnecessary access should be restricted.		
Impact	**An attacker can:** i. Enumerate shared resources within the domain. ii. Gather information about users and systems. iii. Use the collected information to support lateral movement.		

Recommendation	**It is recommended to:** i. Restrict unnecessary SMB shares. ii. Apply least-privilege access controls. iii. Disable anonymous SMB enumeration where possible.
Management Response	

3.3.2 Active Directory Enumeration using BloodHound	**Medium**

Identification

Asset	Environment	Tools Used
Active Directory Domain	**TryHackMe VulnNet Active**	**BloodHound**

Condition

Active Directory enumeration was performed using BloodHound to collect information regarding users, groups, computers, and privilege relationships within the domain. The collected data was analyzed to identify potential attack paths and privilege escalation opportunities.

BloodHound is a security assessment tool that visualizes relationships within Active Directory to identify possible paths an attacker may use to obtain elevated privileges.

Proof of Concept:

Active Directory data was collected and analyzed using BloodHound to identify privilege relationships and potential attack paths.

Note: Screenshots were not preserved during the assessment.

Criteria	Administrative privileges should be granted only where necessary, and excessive permissions should be reviewed regularly in accordance with the principle of least privilege.
Impact	**An attacker can:** iv. Identify privilege escalation paths. v. Map relationships between users, groups, and systems. vi. Plan lateral movement throughout the domain.
Recommendation	**It is recommended to:** iv. Regularly review Active Directory permissions. v. Remove unnecessary privileged group memberships. vi. Continuously monitor privileged account activities.
Management Response	

3.3.3 Active Directory Attack Path Analysis		High
Identification		

Asset	Environment	Assessment
Active Directory Domain	**TryHackMe VulnNet Active**	**Attack Path Analysis**

Condition	Analysis of the Active Directory environment identified potential attack paths that could be leveraged to obtain elevated privileges if misconfigurations were exploited. The assessment focused on identifying relationships between users, groups, and systems that may increase the risk of privilege escalation.

Proof of Concept:

Attack path analysis was performed using BloodHound to evaluate privilege relationships and identify potential paths to elevated access.

Note: Screenshots were not preserved during the assessment.

Criteria	Organizations should periodically review Active Directory permissions and implement the principle of least privilege to minimize unnecessary attack paths.
Impact	**An attacker can:** i. Escalate privileges within the Active Directory domain. ii. Gain unauthorized administrative access. iii. Compromise critical domain resources. iv. Increase opportunities for lateral movement.
Recommendation	**It is recommended to:** i. iReview and remove unnecessary administrative privileges. ii. Implement regular Active Directory security audits. iii. Monitor privileged account activity. iv. Enforce least-privilege access throughout the domain.
Management Response	

4. Audit Findings

4.1 Lack of Network Segmentation		**High**
Observation	It was observed that no network segmentation had been implemented between user systems and servers. All systems were located on the same network, allowing unrestricted communication between hosts.	
Criteria	According to ISO/IEC 27001:2022 Annex A 8.22 – Segregation of Networks, networks should be segmented based on business and security requirements to reduce the risk of unauthorized access and lateral movement.	
Risk	Without network segmentation, an attacker who compromises a single host may move laterally across the network and gain access to additional systems and sensitive resources.	
Recommendation	**It is recommended to:** i. Implement network segmentation using VLANs. ii. Separate user, server, and management networks. iii. Restrict unnecessary communication using firewall rules and access control lists (ACLs).	
Management Response		

4.2 No Regular Backups of Critical Systems		**High**
Observation	It was observed that regular backups of critical systems and servers were not performed.	
Criteria	According to ISO/IEC 27001:2022 Annex A 8.13 – Information Backup, backup copies of information, software, and systems should be maintained and tested regularly.	
Risk	Failure to maintain regular backups may result in permanent loss of critical data following hardware failure, ransomware attacks, or accidental deletion.	
Recommendation	**It is recommended to:** i. Establish a regular backup schedule. ii. Store backups securely at an off-site or isolated location. iii. Periodically test backup restoration procedures.	

Management Response	

4.3 Absence of IDS/IPS	**Medium**
Observation	It was observed that no Intrusion Detection System (IDS) or Intrusion Prevention System (IPS) had been implemented within the environment.
Criteria	According to ISO/IEC 27001:2022 Annex A 8.16 – Monitoring Activities, organizations should monitor networks and systems to detect malicious activities and security incidents.
Risk	Without IDS/IPS solutions, malicious activities may remain undetected, increasing the likelihood of successful cyber attacks and delayed incident response
Recommendation	**It is recommended to:** i. Deploy an IDS and/or IPS solution. ii. Continuously monitor network traffic. iii. Configure alerts for suspicious activities.
Management Response	

4.4 Lack of Logging and Monitoring	**Medium**
Observation	It was observed that centralized logging and continuous monitoring mechanisms were not implemented
Criteria	According to ISO/IEC 27001:2022 Annex A 8.15 – Logging, event logs should be generated, protected, and regularly reviewed to support security monitoring and investigations
Risk	Insufficient logging may delay the detection of security incidents and limit the organization's ability to investigate malicious activities.
Recommendation	**It is recommended to:** i. Enable logging on critical systems and applications. ii. ii. Centralize logs using a logging or SIEM solution. iii. Regularly review security logs for suspicious events.
Management Response	

5 Conclusion

The Vulnerability Assessment and Penetration Testing (VAPT) was successfully conducted on the OWASP Broken Web Applications (OWASP BWA) environment, the Damn Vulnerable Web Application (DVWA), and the TryHackMe VulnNet Active laboratory environment.

The assessment identified multiple security vulnerabilities affecting the web applications, network services, and Active Directory environment. These included injection vulnerabilities, security misconfigurations, vulnerable and outdated components, and Active Directory security weaknesses. A basic security audit also identified gaps in network segmentation, backup management, logging and monitoring, intrusion detection, and identity management.

Appropriate remediation recommendations aligned with the OWASP Top 10:2021 and ISO/IEC 27001:2022 were provided to reduce the identified risks and improve the overall security posture of the environment.

Overall, this assessment demonstrated the importance of regular vulnerability assessments, timely patch management, secure system configurations, and continuous security monitoring in maintaining a secure IT environment.

******End of Report******